PAYMENTS · WEBHOOK

PAID?

ARE YOU SURE?





Swipe →

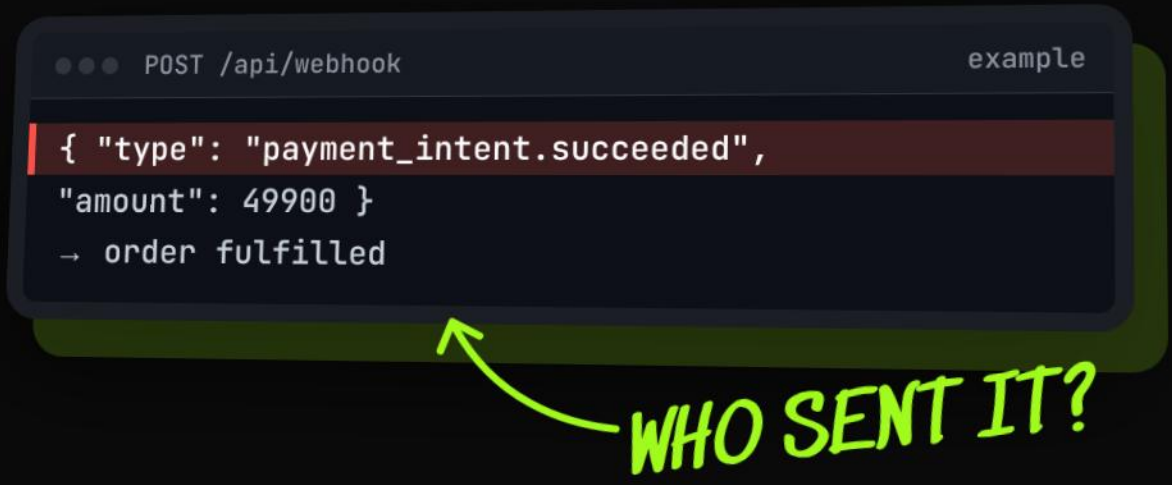
THE RISK

02

ANYONE CAN *SEND IT.*

According to Stripe, without verification an attacker could send fake events to your webhook to fulfil orders, grant account access or modify records.

Stripe Docs · Webhooks



SIGNATURE

03

VERIFY THE SIGNATURE.

Stripe signs every event in the Stripe-Signature header. Verify it with the official library and the endpoint's own secret (whsec_...).

Stripe Docs · Webhooks

webhook.js example

```
const event = stripe.webhooks
.constructEvent(body, sig, secret);
// on error: 400, no fulfilment
```

YOU NEED THIS!

RAW BODY

04

DON'T *TOUCH* THE BODY.

Verification needs the raw, unchanged request body. If your framework parses it into JSON first, verification fails.

Stripe Docs · Webhooks

- ✕ Verifying parsed JSON
- ✕ Ignoring the error to make it work
- ✕ Secret hardcoded in the code

DON'T!

REPLAYS

05

PROCESS IT *ONCE.*

Stripe puts a timestamp in the signature, and the libraries check it with a 5-minute tolerance by default. The same event can arrive twice: log the event IDs you've processed.

Stripe Docs · Webhooks

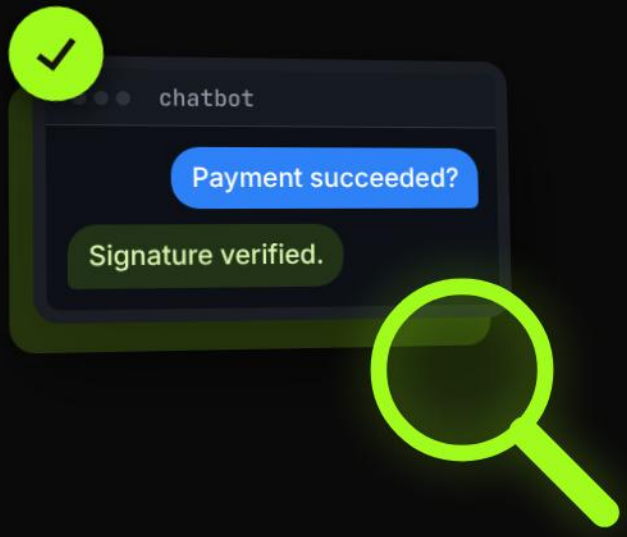


BUILT YOUR APP WITH AI?

WANT ME TO *TAKE A LOOK?*

I'll check what your payment webhook accepts, and from whom.





Message me →